PROBLEMATIKA BEZPEČNOSTI V OBLASTI IT

Malware – škodlivý software

Charakteristika malware

Malware je souhrnné označení pro škodlivý software, který pronikne do systému obvykle bez vědomí uživatele.
Škodlivý software můžeme rozdělit do několika kategorií:

- **infekční** – záměry autora jsou destruktivní; k tomuto typu řadíme viry, červy (worms) ...
- **skrytý** – autor skrytého malware se snaží ovládnout cizí počítač; příkladem jsou trojské koně (trojani), zadní vrátka (backdoor)
- **ziskový** – autor tohoto typu malware se snaží získat ekonomické výhody; příkladem jsou špioni (spyware), roboti a jejich sítě (botnet), odposlechy, dialery.

Viry

Označení vychází z jisté podobnosti s biologickými viry. Za virus pokládáme program, který je schopen se sám replikovat (šířit vlastní kopie), pokud má hostitele (obvykle nějaký spustitelný kód – program, makro). Při spuštění hostitele se provede i kód viru – pokusí se o *sebereplikaci*. Virus pak často zůstává aktivní a snaží se nakazit zpracovávaná data nebo provádět další činnosti, které mohou být velmi rozmanité – od nevinných žertů až po poškozování dat.
Podle hostitele rozeznáváme viry:

- **souborové** – napadají spustitelné soubory;
- **boot viry** – napadají systémové oblasti disku;
- **makroviry** – virus je realizován makrem v dokumentu (nejčastěji pro MS Office); mohou být částečně multiplatformní;
- **skriptové viry** – nejčastěji se objevují ve Visual Basic skriptech a zneužívají slabá místa („díry“) systému Windows.

Červi

K šíření nevyužívají soubory, ale **síťové komunikační služby**. Infikovaný počítač rozesílá do sítě pakety hledající nedostatky pro infikování dalších strojů. Červy nelze zachytit klasickým antivirovým softwarem. Obvykle nevyvíjejí žádnou další činnost, jen se množí a zahlcují komunikační kanály.

Trojské koně

Jde o programy, které předstírají (či vykonávají) určitou užitečnou činnost, ale potají navíc provádějí škodlivé aktivity.
Tzv. **trojani** musí být spuštěni uživatelem, samy se nereplikují, jejich cílem není nakazit další soubory.
Trojské koně můžeme rozdělit podle jejich působení na:

- **password stealing** – programy zachycující stisky kláves a snažící se získat informaci o uživatelských heslech;
- **destruktivní** – poškozují data na disku;
- **dropper** – spouštějí další program, např. červa.

Backdoor („zadní vrátka“)

Tento malware otevírá tajný přístup k počítači. Můžeme jej považovat za speciální případ trojského koně. Ve své podstatě funguje na principu klient-server – umožňuje ovládat na dálku napadený počítač. Mezi nejčastější způsoby zneužití patří odposlech hesel pro další systémy, rozesílání spamu nebo útoky na další systémy včetně zapojení do distribuovaných útoků.

Spyware

Shromažďuje a odesílá citlivá data z uživatelského počítače, např. informace o instalovaném software, soubory s hesly, navštěvované WWW stránky apod. Někdy je součástí aktivit spyware i viditelná činnost (např. zobrazování reklamy). Spyware zneužívá bezpečnostních děr WWW prohlížečů; získané informace bývají prodávány.

Botnet

Jako *bot* (zkráceno ze slova *robot*) je označován program, který potají běží v cizím počítači a je schopen vykonávat příkazy svého původce. Existují rozsáhlé sítě koordinovaných botů, tzv. **botnety**, které se zneužívají pro distribuci spamu, distribuované útoky typu zahlcení apod. Botnety se pronajímají, cena závisí na atraktivitě prostředí (botnet v bankovní síti je pochopitelně dražší než botnet v učebně).

Dialer

Speciální program pro zneužití vytáčeného připojení k Internetu. Bez vědomí uživatele zavěsí a připojí se na jiné telefonní číslo, obvykle zahraniční a velmi drahé. Vlastník čísla inkasuje jako za placenou telefonní službu; uživatel podvod často odhalí až podle vysoké částky telefonního účtu. Tyto hrozby přirozeně ztrácejí na významu přechodem na ADSL.

Hoax

Poplašné zprávy varující před viry typu „Neotevírejte dopisy se jménem Invitation...“. Zatím žádné z těchto varování nebylo reálné, přímo neškodí, ale zahlcují schránky a otravují uživatele. Cílem je vzbuzovat paniku, případně připravovat půdu pro skutečné hrozby. Před přeposláním varování je vhodné ujistit se ve známých databázích hoaxů (např. www.hoax.cz), zda nejde o poplašnou zprávu.

Sociální metody

Jejich snahou je profitovat z šedé operace, nejčastějším cílem je získat přístup ke kontu, případně vydělat na manipulačních poplatcích. Příkladem může být model: „Potřebujeme převést pololegálních 50 mil. USD“ ...
Častou variantou je tzv. **phishing**, jehož cílem může být získání jména a hesla pro přístup do elektronické banky. Modelovým příkladem je rozesílaná podvodná informace, že vaše banka instaluje nový systém a vy se máte přihlásit na (padělané) stránce a vygenerovat si nové heslo. Obranou je získat předem potvrzení o nutnosti takové operace dotazem u vlastní banky.

Viry v elektronické poště

Mohou být spuštěny díky bezpečnostní nedokonalosti poštovního klienta, častěji se však snaží zneužít naivitu a neznalost uživatele. Např. virus *Beagle.M* je v příloze zazipován, archiv je chráněn heslem, které je přiloženo k dopisu jako obrázek – uživatel musí vyvinout značné úsilí, aby si zaviroval počítač, přesto se virus úspěšně šířil. Viry si samy umí najít mailové adresy (díky adresářům) a mohou se tak šířit dál. V současné době jsou spíše na ústupu.

Antivirová ochrana

V souvislosti s antivirovou ochranou existuje řada různých řešení; nejvhodnější je kombinace různých antivirových programů na různých stupních: ochrana celé sítě v bodě jejího připojení k Internetu (kontrola pošty, firewall, detekce útoků) i ochrana koncových stanic. Klíčová je pravidelná aktualizace, protože neaktuální SW může být horší než žádný (falešný pocit bezpečí).

Antivirové programy

Můžeme je rozdělit na:

1. **jednoúčelové**
    - detekují/odstraňují konkrétní infekce, zpravidla zdarma
    - jednoduché skenery
    - provedou kontrolu disku
    - ne vždy dovedou nalezené viry odstranit
2. **komplexní systémy**
    - kromě skenování i rezidentní ochrana – kontrola všech procházejících dat
    - nalezené viry odstraňují (je-li to možné)

Metody skenování

Jde o vyhledávání virových sekvencí - hledá se sekvence podle známé databáze virových kódů (tvůrci antivirových programů dekódují viry ve virtuálním prostředí a záznam jejich kódu ukládají do virové databáze).
Heuristická analýza – speciální metoda, která hledá v kódu operace typické pro viry; díky tomu může být někdy za podezřelý program vydáván i neškodný software, který např. nestandardně přistupuje k operační paměti, obsahuje části kódu vytvořené v assembleru apod.
Generická detekce - představuje zobecnění vyhledávání sekvencí; stejná sekvence se totiž může vyskytovat v různých virech. Je použitelná i pro detekci kódu využívajícího nedostatky zabezpečení.

Kontrola integrity

Vytvoří a uloží si informace o důležitých souborech (kontrolní součty, délky, dobu změny,...) a později ověřuje, zda nedošlo k jejich podezřelé změně. Jde o poměrně jednoduchou a účinnou antivirovou metodu, získané informace lze využít při rekonstrukci napadeného systému. Problémy naopak mohou nastat se soubory, které se mění běžnou činností (např. instalací nových programů); je proto nutné správně vyhodnotit výsledek kontroly a odstraňovat jen ty soubory, které jsou skutečně zasaženy.

Monitorovací systém

Sleduje „živě“ chování programů v systému a snaží se viry identifikovat podle podezřelých aktivit, např. zápis do systémové oblasti disku. Vychází přitom z databáze obvyklých virových operací a postupů. Metoda klade vyšší nároky na správné nastavení systému; její výhodou je, že není nutná tak častá aktualizace antivirové databáze.

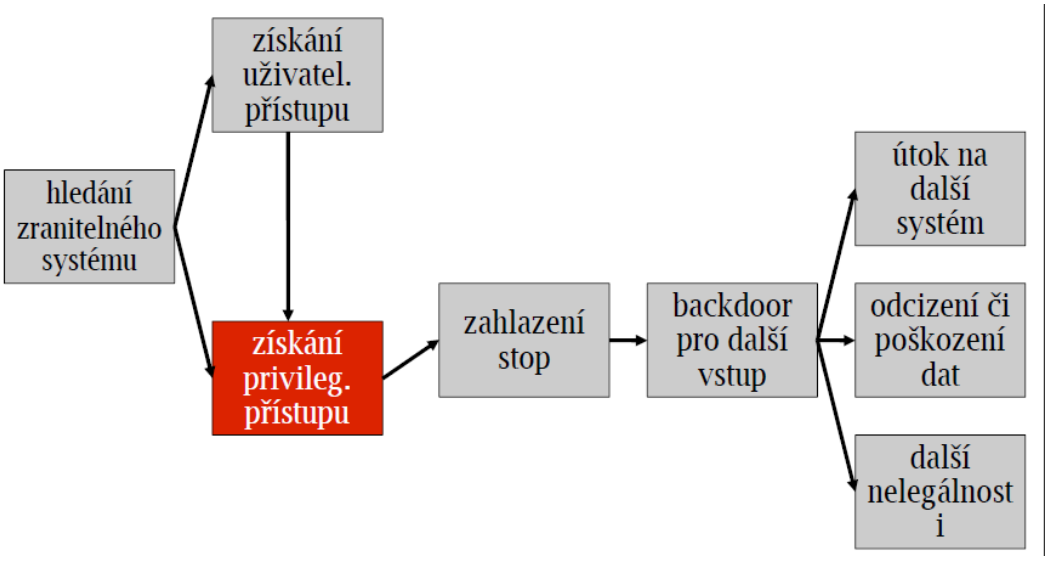
Specializované programy

Zaměřují se na konkrétní malware, např. na spyware a adware (program obtěžující neustále se objevující reklamou):

Bezpečnostní rizika

Na počítač číhá mnoho rizik, patří mezi ně napadení místním uživatelem (krádež/poškození dat), napadení po síti, ale například také požár. Každá ochrana něco stojí, a to nejen finanční prostředky, ale i jistý komfort či flexibilitu. Je proto třeba rozumně vyhodnocovat rizika - pravděpodobnost a důsledky ohrožení i cenu za potřebnou ochranu.

Síťový útok



Hledání zranitelného systému

Využívají se sociální metody (sázka na naivitu uživatelů a jejich nezodpovědné chování – často největší riziko), ale i metody skenování systému ve spojení s programy sledující činnosti na klávesnici (**OS fingerprint**). Pro druhý případ existují speciální aplikace, které zjišťují otevřené porty (služby) na cílovém počítači. Protože části definice TCP/IP nejsou jednoznačné, pakety se liší systém od systému a vytvářejí jeho identifikační otisk. Díky tomu je pak možné zaměřit se na známé slabiny sledovaného systému.

K nejpoužívanějším scannerům patří **Nmap** (případně jeho grafická nadstavba **Zenmap**). Je rozumné pravidelně či příležitostně nechat Nmapem zkontrolovat vlastní stroj, zda nejsou otevřeny nežádoucí porty.

Zahlazení stop

Průnik do systému vyžaduje minimálně pokus o navázání TCP spojení, což po útočníkovi zanechá jasnou stopu (žádost o spojení je zaznamenána do logu). Speciální programy však obsahují metody, které dokážou tento záznam potlačit.

Hardwarové útoky

Jde o útoky (zejména v lokálních sítích), jejímž cílem je fyzické poškození síťového HW – přerušení kabeláže, vyřazení aktivních prvků, rušení signálu pomocí silného elektromagnetického zářiče blízko síťových rozvodů, narušení mikrovlnného spoje apod. Nezřídka mohou být neúmyslné, o to hůře jsou však odhalitelné.
Speciálním typem hardwarových útoků jsou **odposlechy**, jak *fyzické odposlechy* (např. modemu, nebo teoreticky i signálu v kabelu), tak *softwarový odposlech* Ethernetu (sdílené médium doručí signál každému, kdo je připojen; postačí přepnout kartu do tzv. *promiskuitního režimu* – tj. přijímá všechna data, nejen ta, která jí patří). Odposlechů může být využito i při řešení problémů se sítí, např. program **Wireshark** (www.wireshark.org), bývalý **Ethereal**.

Softwarové útoky

Využívá se možných **chyb programů** a rizikových míst v kódu. Příkladem může být tzv. *přetečení zásobníku* (*stack overflow*), kdy aplikace zapíše data do paměti, kam normálně nemá přístup; vede to k provedení útočníkova programu. Účinnou prevencí proti takovým útokům je včasná aktualizace používaných aplikací.
Jiným typem softwarového útoku je tzv. **backdoor**. V tomto případě program (systém) obsahuje skrytý přístup (bezpečnostní „díru“), který si vytvořil autor programu pro ladění aplikace; ten ovšem může později posloužit útočníkovi k napadení počítače. Nebezpečná místa v programovém kódu může odhalit kontrolní skenování.
Velmi časté jsou **útoky proti WWW**. Díky skriptovacím jazykům typu PHP lze snadno vytvářet webové aplikace.Řada programátorů se spokojí s dosažením požadovaných funkcí a neřeší bezpečnostní aspekty – např. předávání parametrů v URL. Volně dostupné aplikace často obsahují zásadní chyby a může být relativně snadné poslat z klientského programu (prohlížeče) podvržená data, aby se obnažily slabiny systému.
V některých případech dochází také k **podvržení identity**. Např. v případě tzv. **IP spoofingu** je do odchozích paketů vkládána falešná (cizí nebo podvržená) IP adresa - odpověď se sice nevrátí zpět, ale výsledek útoku je možné předat jinak.
Tzv. **source routing** představuje variantu, kdy se útočník vydává za důvěryhodný počítač, který předtím vyřadil pomocí DoS útoku (viz dále).

DoS útoky

Z anglického *Denial of Service*; cíl takového útoku je vyřazen z činnosti, často zahlcen.Někdy je DoS útok součástí jiného útoku či zahlazení stop. K DoS útokům se využívá chyb v implementaci IP – může např. dojít k odeslání tzv. *PingOfDeath* paketu („*paketu smrti*“), tedy příliš velkého paketu pomocí příkazu ping, který způsobí zhroucení nekontrolujícího příjemce. Jiné DoS útoky mohou využít nedokonalostí TCP/IP, např. zneužitím ICMP či DNS paketů. Velkou hrozbou je **DDoS útok** (*Distributed Denial of Service*) vedený souběžně z mnoha stanic. Na nezabezpečené počítače je distribuován útočný program (označován jako *zombie*), např. virem. V určitý čas útočník vzbudí zombie a pošle je současně na cíl.

Ochrana před útoky

Osvědčuje se zejména mnoho úrovní zabezpečení:

- autentizace uživatelů sítě – nepovolaným vstup zakázán,
- zabezpečení stanic – ochrana dat zbytku sítě (napadená stanice se stává nástrojem dalšího útoku),
- zabezpečení provozu – sledování provozu sítě, vnitřní filtrování; nejnebezpečnější útoky jsou zevnitř,
- zabezpečení LAN – ochrana LAN před útoky z Internetu,
- zabezpečení na úrovni poskytovatele – neexistuje internetová bezpečnost, ale řadu věcí poskytovatelé sledují či omezují,
- vyčlenit jeden počítač jako tzv. „*lapač útoků*“, který analyzuje přicházející pakety, hledá v nich příznaky útoků a upozorňuje správce; pochopitelně vyžaduje soustavný dohled a rychlou reakci na zjištěné problémy (např. program Snort).

SQL injection

SQL injection je technika napadení databázové vrstvy programu vsunutím (odtud „injection“) kódu přes neošetřený vstup a vykonání vlastního pozměněného SQL dotazu. Toto nechtěné chování vzniká při propojení aplikační vrstvy s databázovou vrstvou (téměř vždy se totiž jedná o dva různé programy) a zabraňuje se mu pomocí jednoduchého „escapování“ potencionálně nebezpečných znaků.
V klasickém případě je útok na internetové stránky prováděn přes neošetřený formulář, manipulací s URL, nebo třeba i podstrčením zákeřně upravené cookie. Bohužel, na internetu je stále velké množství webů spravovaných převážně nezkušenými programátory, kteří o této technice útoku prostě neví a tuto kritickou chybu opomíjejí.

Příklad útoku

Mějme program odesílající dotaz do databáze:

```
statement := "SELECT * FROM uzivatele WHERE jmeno = '" + zadaneJmeno + "';"
```

Pokud však uživatel zadá jako jméno například:

```
a' or 'b'='b
```

aplikační program dotaz doplní a odešle databázi ve formě

```
statement := "SELECT * FROM uzivatele WHERE jmeno = 'a' or 'b'='b';"
```
což může zapříčinit přemostění autorizační procedury, protože 'b' = 'b' je vždy pravda.
Pro SQL injection se dají použít všechny dostupné příkazy, pokud bychom v předešlém příkladě jako jméno zadali:
```
a';DROP TABLE uzivatele; --
```
vypadal by dotaz při odeslání serveru jako:
```
statement := "SELECT * FROM uzivatele WHERE jmeno = 'a';DROP TABLE uzivatele; --';"
```
čímž se nám povedlo smazat celou tabulku uživatelů. Poslední apostrof je pomocí -- zapoznámkován a nemá žádný vliv.

Obrana

1. Na straně aplikace. Nejjednodušší obrana spočívá ve vhodné kontrole a úpravě vstupních dat. Prakticky každý skriptovací program s podporou databáze má nějakou *vestavěnou funkci pro převedení potenciálně nebezpečných znaků* na bezpečnou sekvenci. Tuto funkci je možné použít před vytvořením dotazu.
Pro PHP (v příkladu implementace MySQL):
```
$sql = "SELECT * FROM uzivatele WHERE jmeno = ";
        mysql_real_escape_string($zadaneJmeno);
mysql_query($sql);
//nebo také
$zadaneJmeno=htmlspecialchars($zadaneJmeno, ENT_QUOTES);
$sql = "SELECT * FROM uzivatele WHERE jmeno='{$zadaneJmeno}'";
mysql_query($sql);
```
Dalším bezpečnostním opatřením (může se stát, že na ošetření vstupu někde prostě zapomeneme), je **vypnutí vypisování chyb**. Pokud by pak útočník na nějaký napadnutelný vstup narazil, nedozví se o tom z chybových hlášení.

Na straně databáze

V databázi můžeme útoku zabránit (nebo ho přinejmenším extrémně ztížit) **vhodným nastavením práv uživatele**, se kterými bude program k databázi přistupovat. Málokdy je třeba přímo z aplikační vrstvy mazat tabulky či dokonce databáze, proto stačí povolit jen základní SQL příkazy.

Problém autentizace

Typy autentizace

Autentizace uživatele představuje základní prvek ochrany sítí a systémů. Kromě povolení přístupu lze uživatele členit do skupin, nastavovat různá oprávnění apod. Nejčastěji se autentizace provádí spojením uživatelského jména a hesla, lze se však setkat i s případy použití jednorázového hesla, s **hardwarovou identifikací** (kartou, klíčem,...) či **biometrickou identifikací** (otisky prstů, sítnice, hlas,...).

Útoky na hesla

Jednou z nejsnadnějších cest k útoku je získat heslo existujícího uživatele (nejlépe superuživatele). Tzv. **útoky na hesla** jsou prováděny buď **hrubou silou** (program zkouší mnoho hesel - všechny možné kombinace, případně se zkouší slova ze slovníku a jejich modifikace), nebo na základě **analýzy sociálního chování uživatelů** (zadávání hesel se jmény svých blízkých, datem narození atd.). Nejúčinnější obranou před online útokem je zablokování účtu po několika špatných heslech a prodlužování časové odezvy. Možnou obranou před offline útokem je periodická změna hesla a požadavek na kvalitní heslo.

Vytváření tzv. silného hesla

Heslo by mělo být tvořeno aspoň 8 znaky – kombinace abecedních znaků (malá i velká písmena), numerických znaků a speciálních znaků. Čím větší je množina použitých znaků a čím je heslo delší, tím je silnější a bezpečnější.
Vytváření hesel pomocí akronymů (počátečních znaků slov):

- `sNdz,nl` – *šla Nanynka do zelí, natrhala lupení*
- `MV:Blpp,92` – *Michal Viewegh: Báječná léta pod psa, 1992*

Autentizace v síti

Základním problémem je přenos hesla sítí:

- **nešifrované heslo** lze odposlechnout (dnes spíše historická záležitost),
- **šifrovaný přenos** – existuje řada systémů i algoritmů,
- **centrální autentizace** – řada systémů, často jen pro jedno prostředí (Windows Domain, Novell), k multiplatformním řešením patří Kerberos, DCE, Sesame.

Kerberos – autentizační systém

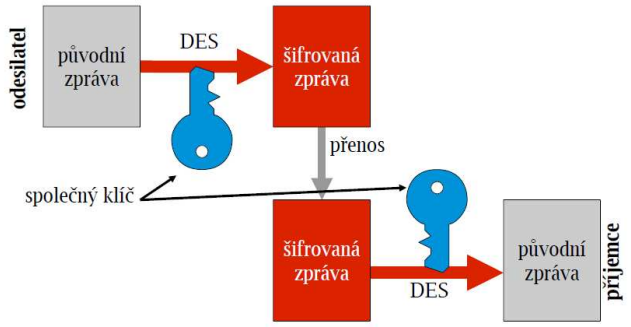
Příkladem autentizačního systému uživatelů i služeb je multiplatformní systém **Kerberos**. Základem je centrální server s databází uživatelů a serverů.
Samotná autentizace je řešena formou tzv. *vstupenek* (*tickets*) – jde o jednorázová oprávnění pro přístup ke službě. Tím, že ticket platí pro konkrétní službu omezenou dobu, se snižuje riziko zneužití.
Předpokladem práce v systému je **TGT** – *Ticket to Grant Ticket* (vstupenka pro získání vstupenek), jež slouží jako identifikátor uživatele pro další autentizace. V přihlašovacím dialogu uživatel zadá jméno a heslo; heslem se zašifruje aktuální čas (silné šifrování algoritmem 3DES) a spolu se jménem je odeslán na autentizační server. Server příslušným heslem dešifruje čas a porovná se svým (ochrana proti podvržení vstupenky). Je-li autentizace úspěšná, vygeneruje TGT a zašifrované heslem vrátí uživateli.
Po autentizaci uživatel získá od serveru klíč k sezení a dále vstupenku pro další autentizaci zašifrovanou jak klíčem sezení, tak klíčem služby pro autentizaci. Při použití síťové služby (např. souborový server) pak s použitím klíče požádá autentizační server o vstupenku opravňující k jejímu použití; její součástí je identifikace používané služby – klient má jistotu, že používá skutečně požadovaný server, nikoli jeho padělek. Klíč sezení se generuje náhodně a má omezenou životnost – není technicky možné zjistit jej hrubou silou.

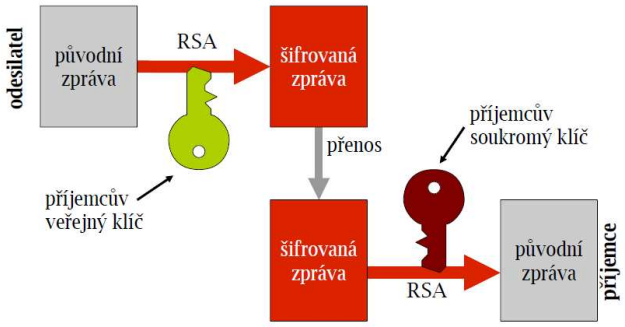
Šifrování

Kryptologie – věda o šifrách.
Kryptografie – část kryptologie zabývající se převedením srozumitelné zprávy do nesrozumitelné podoby a zpět (šifrování a dešifrování).
Kryptoanalýza – část kryptologie zabývající se odhalením klíče.

Typy šifrování

Symetrické šifrování	Asymetrické šifrování
Velmi rychlý typ šifrování, při němž platí **stejný klíč** pro šifrování i dešifrování. Používané šifrovací algoritmy (např. DES, 3DES, IDEA, Blowfish) jsou veřejně popsány; bezpečnost vychází z jejich principů a síla šifer se vyjadřuje délkou klíče (za bezpečné jsou považovány klíče nad 128 bitů). Každá dvojice potřebuje svůj klíč a problémem je jejich předávání.	Využívá **dvojice klíčů** - **veřejný** a **soukromý**. Veřejný může použít kdokoli pro zašifrování zprávy, ale dešifrovat lze jen pomocí soukromého klíče. Soukromý klíč neopustí vlastníka, nelze jej odvodit z veřejného klíče. Pro šifrování se požívají algoritmy RSA, Diffie-Hellman, DSS, které jsou mnohem (řádově 1 000x) pomalejší než symetrické; klíče mohou mít velikost i několik kilobitů.

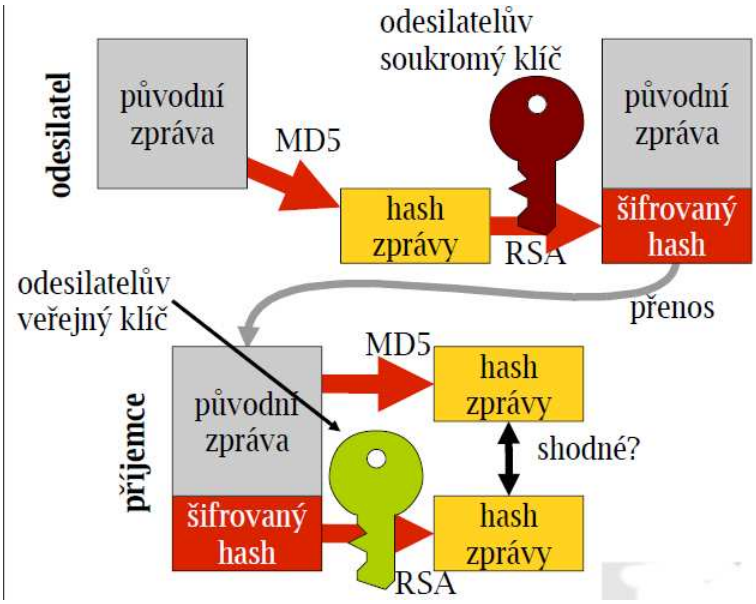




Elektronický podpis

Vychází z asymetrického šifrování - ke zprávě se vytvoří *kontrolní součet* (**hash** - např. algoritmem MD5), který se šifruje soukromým klíčem. Příjemce dešifruje veřejným klíčem odesilatele a pokud souhlasí s kontrolním součtem došlé zprávy, ví, že zpráva pochází skutečně od odesilatele (**autorizace**) a že zpráva nebyla cestou změněna (**integrita**).
Principem běžného elektronického podpisu je tedy zašifrování dokumentu tajným klíčem a jeho následné dešifrování veřejným klíčem. "Tajný klíč" a "veřejný klíč" si můžeme představit jako dvě velmi vysoká čísla. Aby bylo šifrování účinné, nesmí být znám postup, pomocí kterého by bylo možné ani s nasazením nejdokonalejších počítačů vypočítat z veřejného klíče tajný klíč. Kdo nezná tajný klíč není schopen zašifrovat dokument tak, aby jej bylo možné dešifrovat veřejným klíčem. Tajný klíč tedy nesmí znát nikdo jiný, než autor dokumentu.
Z praktických důvodů se místo celého dokumentu šifruje pouze jeho hash - což je jakási digitální obdoba otisku prstů. Při vytváření hashe pro šifrovací účely se používají takové algoritmy, že je prakticky vyloučené změnit dokument takovým způsobem, aby se současně nezměnil jeho hash. Příkladem jednoduchého hashe (pro kryptografii nepoužitelného) je kontrolní součet řady čísel, používaný pro ověření že při jejich přepisování nedošlo k chybě. Hash je většinou mnohem kratší než celý dokument. Výhodou šifrování hashe místo celého dokumentu je čitelnost dokumentu i bez klíče a vyšší rychlost šifrování a dešifrování, která dovoluje použití složitějších (a tedy bezpečnějších) šifrovacích algoritmů.
Nejprve se vytvoří otisk (tzv. hash) dokumentu, což je poměrně krátký (typicky několik stovek bitů) výtah vytvořený specializovaným algoritmem z celého dokumentu. Tento hash se poté zašifruje autorovým tajným klíčem, čímž vznikne

podpis. Ověření podpisu pak spočívá v dešifrování hashe (podpisu) pomocí veřejného klíče autora, nezávislého výpočtu hashe z dokumentu a porovnání obou hodnot. Pokud si odpovídají, pak je podpis ověřen a dokument je považován za důvěryhodný. Autor nemůže popřít své autorství - pokud k jeho tajnému klíči nikdo jiný nemá přístup, pak nikdo jiný nemůže zašifrovat hash dokumentu tak, aby po aplikaci autorova veřejného klíče vznikla správná hodnota. Pokud by byl dokument po podepsání změněn nebo poškozen, vyšla by jiná hodnota hashe, takže elektronický podpis by byl neplatný.



Kombinované šifrování

Žádná z metod není ideální: symetrické šifrování vyžaduje stejné klíče a asymetrické šifrování je výpočetně náročné (pomalé). Řešením je proto kombinace obou metod - zpráva se zašifruje symetrickou šifrou, klíč pro symetrickou šifru se zašifruje asymetricky a přiloží ke slávě. Asymetricky se šifrují/dešifrují jen malá data, klíč pro symetrickou šifru se přepraví bezpečně.

Certifikační autority

Veřejné asymetrické klíče lze volně distribuovat, a problémem proto je jak důvěryhodně získat něčí veřejný klíč. Řešení poskytují tzv. **certifikáty** vydávané organizací zvanou **certifikační autorita** (CA). Ta potvrdí svým podpisem, že klíč patří danému uživateli či serveru. Veřejný klíč CA přitom potvrdí svým certifikátem vyšší CA – musí tedy existovat hierarchie CA označovaná *Public Key Infrastructure* (PKI). Teoreticky poté stačí veřejný klíč kořene PKI k ověření všech ostatních klíčů.

Zásady bezpečného chování v počítačové síti

- Používání kvalitního firewallu – speciální program, který chrání lokální síť a počítač před útoky z vnějšího prostředí. Kromě firewallu, který je součástí OS, lze použít některý ze specializovaných programů, například Kerio personall firewall.
- Pravidelně provádět aktualizace operačního systém (automatická aktualizace, tzv. service packy – update systému apod.).
- Používat kvalitní antivirový program, v počítačové síti vícestupňovou antivirovou ochranu.
- Nainstalovat a využívat kvalitní antispyware s rezidentním štítem, který dokáže zastavit malware ještě předtím, než se dostane na PC.
- Příležitostně spouštět antivirové a antispywarové testy, případně si nastavit automatické skenování na určitou hodinu denně.
- Pravidelně a promyšleně zálohovat data; využívat k tomu možností dynamických disků a diskových polí.
- Používat silná hesla, nesdílet je a v pravidelných intervalech je obměňovat.
- Nesdílet složky pro zápis, není-li to bezprostředně nutné. Po použití sdílení složky vypínat. Nikdy nesdílet celý systémový disk nebo systémové adresáře.
- Být obezřetní při použití internetu - stahování souborů, otevírání podezřelých stránek a podezřelé pošty.
- Pro větší bezpečnost používat kvalitní alternativní programové vybavení, které není využíváno většinou běžných uživatelů.
- Zvážit vypnutí používání rizikových prvků jako Active X, skriptů, případně i cookies.
- Používat legální software.
- Nezapínat makra v Microsoft Office, pokud to není nezbytné.